



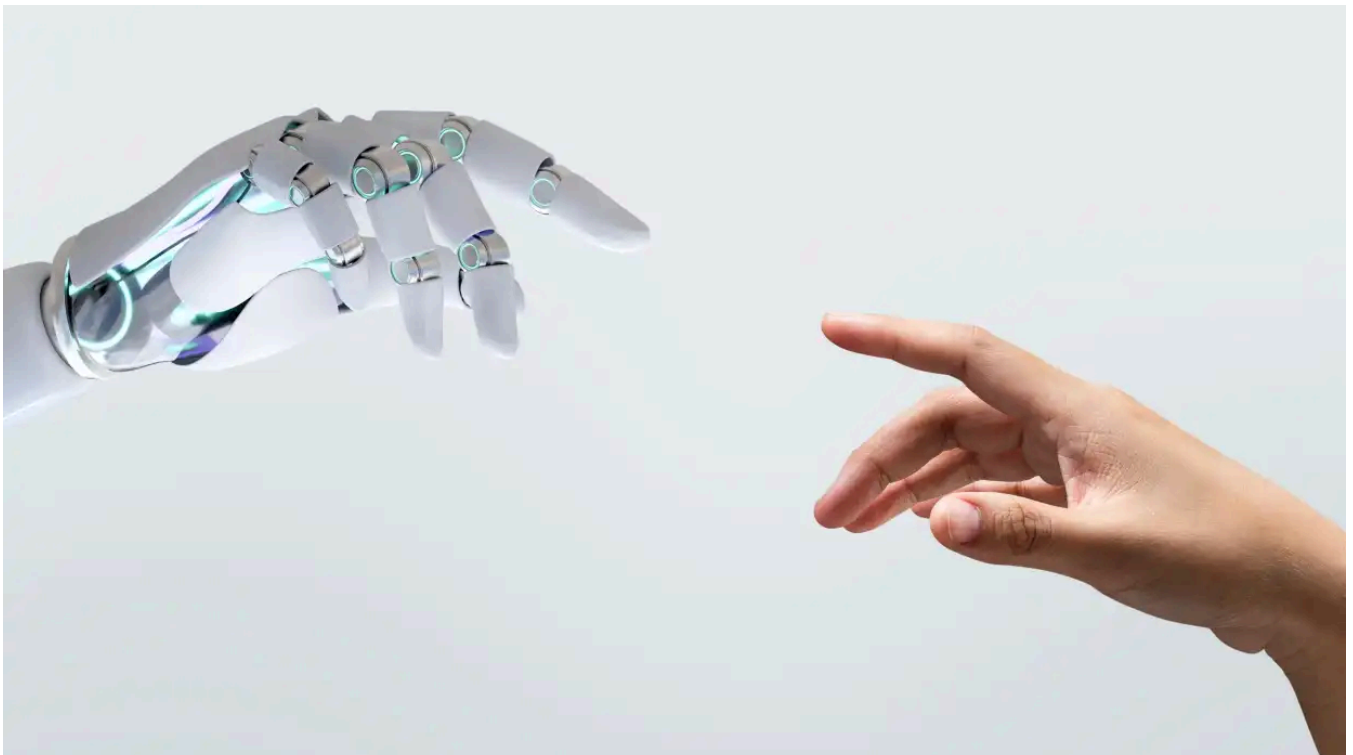
by **Shweta Sharma**
Senior Writer

Human oversight is still critical as AI patching tools miss security risks

News

Aug 7, 2026 • 3 mins

1Password researchers found LLM-generated fixes often overlooked root causes, architectural context, and long-term security implications in complex vulnerability patches.



Credit: Rawpixel.com / Shutterstock

AI-generated vulnerability patches still heavily depend on human review, particularly the ones involving security-sensitive code, according to a research.

Researchers from 1Password have disclosed an internal evaluation that found AI-generated fixes frequently overlook broader **concerns** [<https://www.csoonline.com/article/4202381/risk-based-patching-is-the-future-ai-made-it-table-stakes.html>] such as architectural intent, business requirements, security implications, and long-term maintainability, despite being syntactically correct.

“We studied what happens when Large Language Models (LLMs) generate vulnerability patches for recently disclosed, complex vulnerabilities,” said 1Password researcher **Keith Hoodlet** [<https://www.linkedin.com/in/securingdev/>] in a blog **post** [<https://1password.com/blog/why-ai-generated-patches-still-require-human-review>]. “Our data shows that LLMs produce Fix-Like Artifacts with Embedded Defects (FLAWED) 53.9% of the time when complex patches are required.”

The evaluation tested the AI-generated fixes across six recently disclosed CVEs, including CVE-2026-31431 (“**Copy Fail** [<https://www.csoonline.com/article/4169399/new-dirty-frag-exploit-tar-gets-linux-kernel-for-root-access.html>]”), CVE-2026-34197 (**ActiveMQ RCE** [<https://www.csoonline.com/article/4157146/claude-uncovers-a-13%E2%80%91year%E2%80%91old-activemq-rce-bug-within-minutes.html>]), CVE-2026-8512, CVE-2026-45185 (EXIM RCE), CVE-2026-22738 (**SpringAI SpEL RCE** [<https://nvd.nist.gov/vuln/detail/cve-2026-22738>]), and the **Gemini CLI RCE** [<https://www.csoonline.com/article/4165470/max-severity-rce-flaw-found-in-google-gemini-cli.html>] (GHSA-wpqr-6v78-jr5g).

1Password reportedly evaluated 6080 patches generated using ChatGPT-5.5 and Claude Opus 4.8, two frontier AI coding models, and found that only a little over a quarter of the fixes fully remediated the flaw without altering application behavior.

“Patches that successfully resolved the vulnerability, but altered the application’s behavior in the process, occurred 20.1% of the time,” Hoodlet added.

Fixing is not the same as securing

Instead of simply checking whether the fixed code compiled or passed automated tests, 1Password said it reviewed every generated fix for complete elimination of the vulnerability, preservation of application behavior, and avoidance of new security risks.

While only 26% of the patches successfully fixed the vulnerability without introducing application changes, 49.3% failed to remove at least one exploitable attack path, 2.3% fixed the original vulnerability but introduced a new one, and 2.2% both failed to remediate the issue and created an additional security weakness.

The researchers also found that passing pre-defined tests can create deeper problems. More than one-third of the patches that initially appeared successful were classified as “fragile” because they simply blocked the proof-of-concept (POC) exploit used during testing instead of addressing the underlying root cause. Hoodlet explained this with the example of the SpringAI CVE patches. Both GPT and Claude models were found generating patches that targeted specific characters from the input string used in the POC presented to them, leaving the root cause untouched.

“If the guarded code were to become reachable again by using alternative inputs, it would lead to the old vulnerability resurfacing in the software,” he noted.

Human review remains the last security control

1Password argues that these shortcomings stem from the contextual reasoning required to produce production-ready security fixes.

Anthropic was reached out to and reportedly recommended keeping humans in the loop. “Patch generation has outpaced patch verification, and the fix is to make verification execution-grounded rather than inspection-based, while keeping domain experts as the final reviewers at current model capabilities,” it was quoted as saying.

1Password also challenged the notion that AI-generated patches are effectively “free.” While the average patch-and-validation cycle cost approximately \$2.11 using ChatGPT-5.5 and \$2.81 using Claude Opus 4.8, Hoodlet argued that the real expense lies in validating whether those patches are secure enough for production.

Artificial Intelligence[https://www.csoonline.com/artificial-intelligence/]

Vulnerabilities[https://www.csoonline.com/vulnerabilities/]

Security[https://www.csoonline.com/security/]



More



Our Network

